

Cybersecurity Plan DnDiscord

DnDiscord - Cybersecurity Plan

Document Version: 1.0

Date: December 12, 2025

Classification: Internal - Confidential

Project: T-ESP-800 - DnDiscord Virtual Tabletop Platform

Table of Contents

- [1. Executive Summary](#)
- [2. Scope and Objectives](#)
- [3. Security Architecture Overview](#)
- [4. Asset Inventory and Classification](#)
- [5. Threat Assessment](#)
- [6. Risk Assessment](#)
- [7. Security Controls and Mitigations](#)
- [8. Compliance Requirements](#)
- [9. Incident Response Plan](#)
- [10. Security Testing Requirements](#)
- [11. Monitoring and Logging Strategy](#)
- [12. Business Continuity and Disaster Recovery](#)
- [13. Security Awareness and Training](#)
- [14. Document Control and Review](#)
- [15. References and Sources](#)

1. Executive Summary

1.1 Purpose

This Cybersecurity Plan establishes the security framework for DnDiscord, a web-based virtual tabletop application integrated with Discord. The platform enables real-time multiplayer tabletop roleplaying games with 3D visualization, requiring robust security measures to protect user data, ensure service availability, and maintain compliance with applicable regulations.

1.2 Key Security Objectives

The security program for DnDiscord is built around the CIA triad plus additional considerations:

Objective	Description	Priority
Confidentiality	Protect user personal data, game content, and authentication credentials	Critical
Integrity	Ensure game state consistency and prevent unauthorized modifications	High
Availability	Maintain 99.5% uptime for real-time multiplayer functionality	High
Authentication	Secure Discord OAuth integration and session management	Critical
Non-repudiation	Maintain audit trails for administrative actions	Medium

1.3 Risk Summary

Based on our threat assessment, the overall risk profile is **MEDIUM-HIGH**, primarily driven by:

- GDPR compliance requirements for European users (especially minors under 15 in France)
- Real-time WebSocket communications requiring constant security monitoring
- Third-party dependency on Discord's platform and API
- Processing of user-generated content and personal data

2. Scope and Objectives

2.1 In Scope

Component	Description
Frontend Application	SolidJS web application with BabylonJS 3D rendering

Component	Description
API Gateway	Ocelot gateway with authentication and routing
Backend Services	ASP.NET Core microservices (User, Campaign, Character, Combat, Chat)
Game Server	WebSocket-based real-time communication server
Data Storage	PostgreSQL databases and caching layers
Infrastructure	Docker containers, CI/CD pipelines, monitoring systems
External Integrations	Discord API, OAuth2 authentication

2.2 Out of Scope

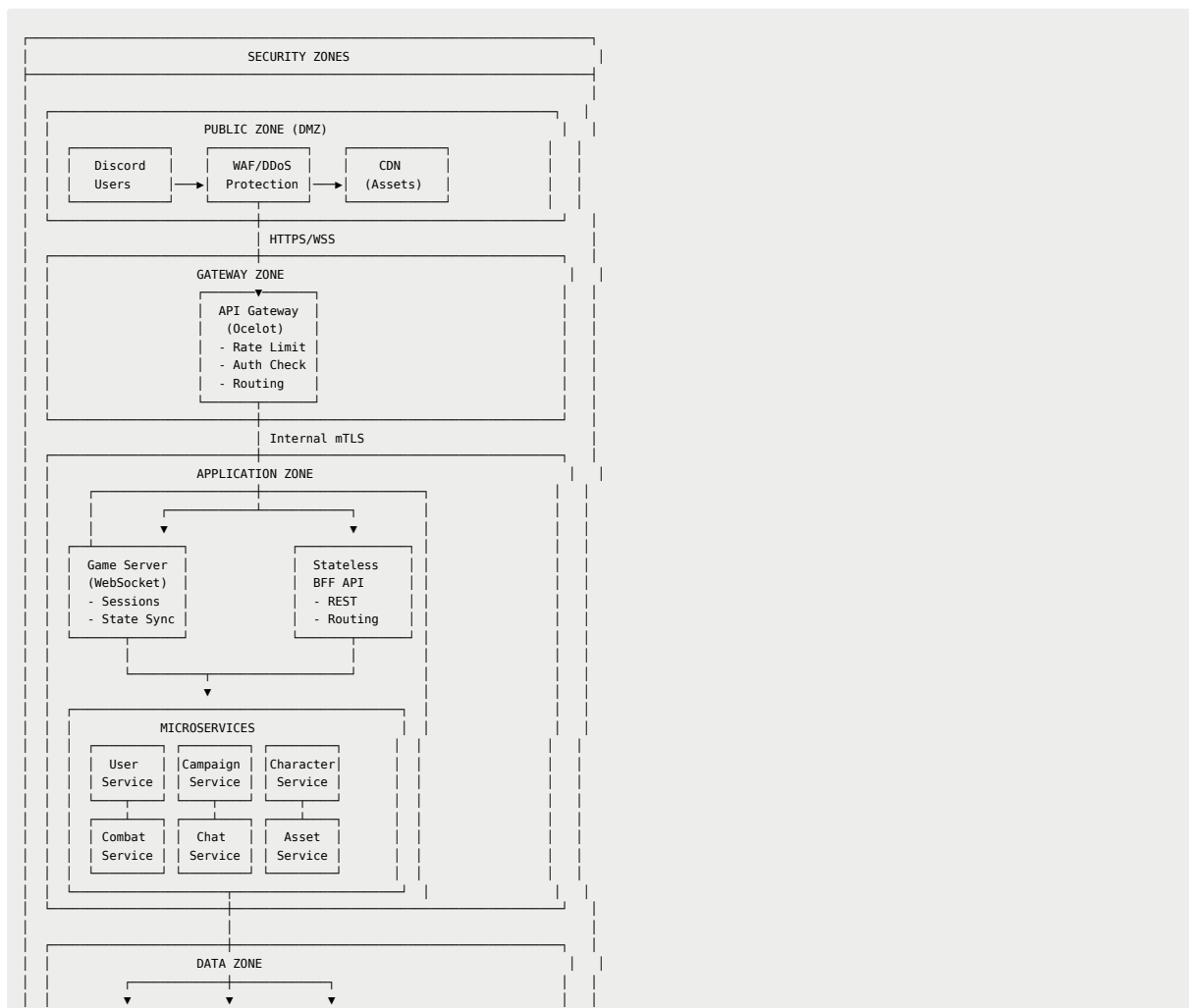
- End-user device security
- Discord platform security (managed by Discord)
- Third-party library internal security (managed through dependency scanning)
- Physical security of cloud infrastructure (managed by cloud provider)

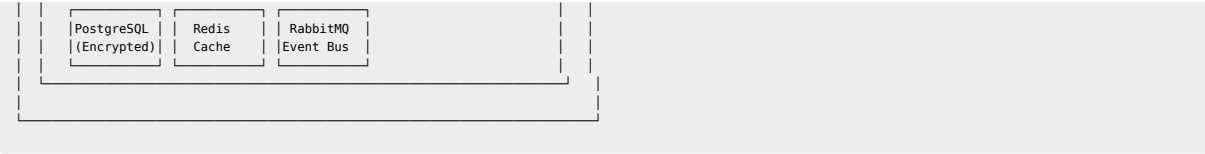
2.3 Security Objectives

1. **Protect Personal Data:** Implement GDPR-compliant data handling practices
2. **Secure Authentication:** Ensure robust Discord OAuth2 integration
3. **Prevent Unauthorized Access:** Implement role-based access control (RBAC)
4. **Maintain Game Integrity:** Prevent cheating and state manipulation
5. **Ensure Service Resilience:** Protect against DDoS and service disruption
6. **Enable Secure Communications:** Encrypt all data in transit and at rest

3. Security Architecture Overview

3.1 Architecture Diagram





3.2 Security Layers

Layer	Security Controls
Network	WAF, DDoS protection, TLS 1.3, network segmentation
Gateway	Rate limiting, JWT validation, request filtering
Application	Input validation, CORS, CSP headers, RBAC
Data	Encryption at rest (AES-256), field-level encryption for PII
Infrastructure	Container security, secrets management, vulnerability scanning

4. Asset Inventory and Classification

4.1 Data Classification Matrix

Classification	Description	Examples	Handling Requirements
PUBLIC	Non-sensitive, publicly available	Game rules, public assets	No restrictions
INTERNAL	Business-sensitive, internal use	Architecture docs, API specs	Access control required
CONFIDENTIAL	User personal data	Email, Discord ID, IP addresses	Encryption + access logging
RESTRICTED	Highly sensitive data	Authentication tokens, passwords	Encryption + strict access + audit

4.2 Critical Assets Inventory

Asset ID	Asset Name	Type	Classification	Owner	CIA Rating
A-001	User Personal Data	Data	CONFIDENTIAL	Data Protection Officer	C:H I:H A:M
A-002	Authentication Tokens	Data	RESTRICTED	Security Team	C:C I:C A:H
A-003	Game State Data	Data	INTERNAL	Game Server Team	C:M I:H A:H
A-004	Campaign Content	Data	CONFIDENTIAL	Users	C:H I:H A:M
A-005	Source Code	Code	CONFIDENTIAL	Development Team	C:H I:H A:M
A-006	API Gateway	Infrastructure	INTERNAL	DevOps Team	C:H I:H A:C
A-007	Database Servers	Infrastructure	RESTRICTED	DevOps Team	C:C I:C A:C
A-008	Encryption Keys	Data	RESTRICTED	Security Team	C:C I:C A:H

Legend: C = Confidentiality, I = Integrity, A = Availability | H = High, M = Medium, C = Critical

5. Threat Assessment

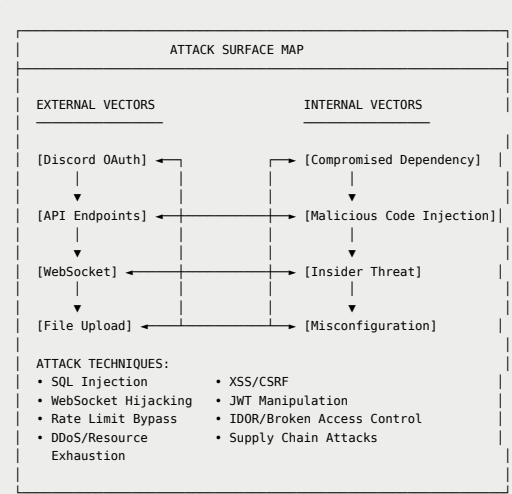
5.1 STRIDE Threat Model

Threat Category	Description	Applicable Components	Potential Impact
Spoofing	Impersonating users or services	Auth system, API endpoints	Unauthorized access, data breach
Tampering	Modifying data or code	Game state, user profiles, requests	Data corruption, cheating
Repudiation	Denying actions	Admin actions, transactions	Accountability issues
Information Disclosure	Unauthorized data access	Database, API responses, logs	Privacy breach, GDPR violation
Denial of Service	Service disruption	WebSocket server, API gateway	Loss of availability
Elevation of Privilege	Gaining unauthorized permissions	RBAC system, admin functions	Full system compromise

5.2 Threat Actors Profile

Actor Type	Motivation	Capability	Target Assets	Likelihood
Script Kiddies	Fun, bragging rights	Low	Public-facing services	High
Cheaters/Griefers	Unfair advantage, disruption	Low-Medium	Game state, WebSocket	High
Cybercriminals	Financial gain, data theft	Medium-High	User data, credentials	Medium
Competitors	Business intelligence	Medium	Source code, user base	Low
Nation States	Espionage, disruption	High	Infrastructure, user data	Very Low
Malicious Insiders	Various	Medium-High	All assets	Low

5.3 Attack Vectors



5.4 Detailed Threat Scenarios

ID	Threat Scenario	Attack Vector	Affected Assets	Business Impact
T-001	OAuth Token Theft	Man-in-the-middle, XSS	User accounts	Account takeover, privacy breach
T-002	Game State Manipulation	WebSocket injection	Game sessions	Cheating, user trust loss
T-003	SQL Injection	Malicious input	Database	Data breach, data loss
T-004	DDoS Attack	Volumetric/Application layer	All services	Service unavailability
T-005	Session Hijacking	Token theft, replay attack	User sessions	Unauthorized access
T-006	Data Exfiltration	SQL injection, API abuse	User PII	GDPR violation, fines
T-007	Privilege Escalation	IDOR, RBAC bypass	Admin functions	Full system compromise
T-008	Supply Chain Attack	Compromised npm/NuGet package	Application code	Code execution, backdoor

6. Risk Assessment

6.1 Risk Assessment Methodology

Risk is calculated using the formula:

Risk Score = Likelihood × Impact

Likelihood Scale

Level	Score	Description	Frequency
Very Low	1	Rare, requires exceptional circumstances	< 1% annually
Low	2	Unlikely but possible	1-10% annually
Medium	3	Possible under certain conditions	10-50% annually
High	4	Likely to occur	50-90% annually
Very High	5	Almost certain to occur	> 90% annually

Impact Scale

Level	Score	Description	Business Impact
Negligible	1	Minimal impact	< €1,000
Minor	2	Limited impact, easily recoverable	€1,000 - €10,000
Moderate	3	Significant impact, requires effort to recover	€10,000 - €100,000
Major	4	Severe impact on operations	€100,000 - €1,000,000
Critical	5	Catastrophic, existential threat	> €1,000,000 or regulatory fines

6.2 Risk Matrix

		IMPACT				
		1 Neglig	2 Minor	3 Moder	4 Major	5 Crit
L I K E	5 VHi	5 Low	10 Med	15 High	20 Crit	25 Crit
	4 Hi	4 Low	8 Med	12 High	16 High	20 Crit

L						
I	3	Med	3	6	9	12
H			Low	Low	Med	High
O	2	Lo	2	4	6	8
D			Low	Low	Low	Med
	1	VLo	1	2	3	4
			Low	Low	Low	Low

Risk Levels:

LOW (1-5)  Accept with monitoring

MEDIUM (6-10)  Mitigate within 90 days

HIGH (11-16)  Mitigate within 30 days

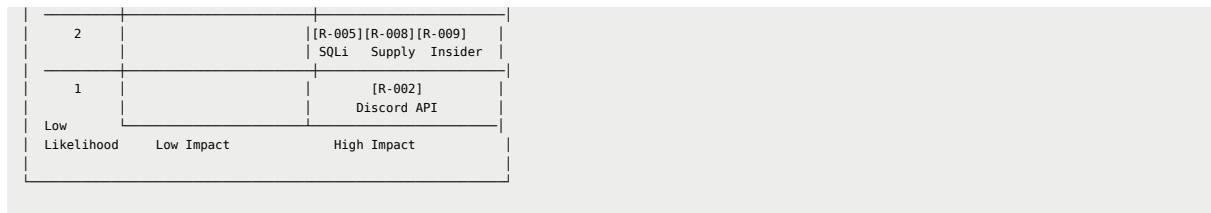
CRITICAL (17-25)  Immediate action required

6.3 Risk Register

Risk ID	Risk Description	Threat	Likelihood	Impact	Risk Score	Risk Level	Mitigation Strategy	Residual Risk
R-001	GDPR Non-Compliance	Data breach exposing EU user data	3	5	15	HIGH	Implement data encryption, consent management, DPO appointment	6 (Medium)
R-002	Discord API Dependency	Discord service outage or API changes	3	4	12	HIGH	Graceful degradation, cached data, user notification	6 (Medium)
R-003	WebSocket DoS	Malicious WebSocket flood	4	3	12	HIGH	Rate limiting, connection throttling, auto-scaling	4 (Low)
R-004	Session Hijacking	Token theft via XSS	3	4	12	HIGH	HttpOnly cookies, CSP headers, token rotation	4 (Low)
R-005	SQL Injection	Data breach via SQLi	2	5	10	MEDIUM	Parameterized queries, WAF, input validation	3 (Low)
R-006	Game State Tampering	Cheating via message manipulation	4	2	8	MEDIUM	Server-side validation, signed messages, anti-cheat	4 (Low)
R-007	Credential Stuffing	Account takeover	3	3	9	MEDIUM	Discord OAuth only, MFA via Discord, rate limiting	3 (Low)
R-008	Supply Chain Attack	Compromised dependency	2	5	10	MEDIUM	Dependency scanning, SCA tools, lockfiles	4 (Low)
R-009	Insider Threat	Data theft by team member	2	4	8	MEDIUM	Least privilege, audit logs, code review	4 (Low)
R-010	Minor Data Protection	Parental consent for French users <15	3	5	15	HIGH	Age verification, parental consent flow	5 (Low)

6.4 Risk Heat Map

RISK HEAT MAP			
Very High Likelihood 5			
4	[R-003] WebSocket DoS	[R-006] Game Tampering	
3	[R-007] Credential Stuffing	[R-001][R-004][R-010] GDPR Session Minors	



7. Security Controls and Mitigations

7.1 Authentication & Access Control

Control ID	Control Name	Description	Implementation	Status
AC-001	Discord OAuth2	All authentication via Discord OAuth2	Duende Identity Server	Planned
AC-002	JWT Tokens	Short-lived access tokens (15 min)	RS256 signed JWTs	Planned
AC-003	Refresh Tokens	Secure refresh token rotation	HttpOnly cookies, SameSite=Strict	Planned
AC-004	RBAC	Role-based access control	Claims-based authorization	Planned
AC-005	Session Management	Secure session handling	Redis session store, encryption	Planned
AC-006	Rate Limiting	Request throttling	Ocelot rate limiting middleware	Planned

7.2 Data Protection Controls

Control ID	Control Name	Description	Implementation	Status
DP-001	Encryption at Rest	AES-256 for stored data	PostgreSQL TDE, column encryption	Planned
DP-002	Encryption in Transit	TLS 1.3 for all communications	Certificate management, HSTS	Planned
DP-003	Data Minimization	Collect only necessary data	Schema review, field audit	Planned
DP-004	Data Retention	Automated data deletion	Background jobs, retention policies	Planned
DP-005	Backup Encryption	Encrypted database backups	AES-256 encrypted backups	Planned
DP-006	PII Masking	Mask PII in logs	Structured logging with redaction	Planned

7.3 Application Security Controls

Control ID	Control Name	Description	Implementation	Status
AS-001	Input Validation	Validate all user inputs	FluentValidation, model binding	Planned
AS-002	Output Encoding	Prevent XSS attacks	Context-aware encoding	Planned
AS-003	CSRF Protection	Anti-forgery tokens	ASP.NET Core Antiforgery	Planned
AS-004	CSP Headers	Content Security Policy	Strict CSP implementation	Planned
AS-005	SQL Injection Prevention	Parameterized queries only	Entity Framework Core, Dapper	Planned
AS-006	WebSocket Security	Secure WebSocket handling	Origin validation, message signing	Planned
AS-007	File Upload Security	Secure file handling	Type validation, sandboxing	Planned

7.4 Infrastructure Security Controls

Control ID	Control Name	Description	Implementation	Status
IS-001	Container Security	Hardened Docker images	Non-root users, minimal base images	Planned
IS-002	Secrets Management	Secure credential storage	Azure Key Vault / HashiCorp Vault	Planned
IS-003	Network Segmentation	Isolated network zones	Docker networks, firewall rules	Planned
IS-004	Vulnerability Scanning	Automated security scanning	Dependabot, Snyk, Trivy	Planned
IS-005	DDoS Protection	Distributed denial of service mitigation	Cloudflare, rate limiting	Planned
IS-006	WAF	Web Application Firewall	OWASP Core Rule Set	Planned

7.5 Control Mapping to OWASP Top 10 (2021)

OWASP Top 10	Risk	Controls Applied
A01:2021 - Broken Access Control	Unauthorized access to resources	AC-004, AC-006, AS-006
A02:2021 - Cryptographic Failures	Sensitive data exposure	DP-001, DP-002, DP-005
A03:2021 - Injection	SQL/NoSQL/Command injection	AS-001, AS-005, AS-006
A04:2021 - Insecure Design	Architectural vulnerabilities	Security architecture review
A05:2021 - Security Misconfiguration	Default/insecure configurations	IS-001, IS-002, IS-003
A06:2021 - Vulnerable Components	Known vulnerabilities in dependencies	IS-004
A07:2021 - Authentication Failures	Broken authentication	AC-001, AC-002, AC-003
A08:2021 - Software and Data Integrity Failures	CI/CD security, supply chain	IS-004, signed commits

OWASP Top 10	Risk	Controls Applied
A09:2021 - Security Logging and Monitoring	Insufficient logging	Monitoring section
A10:2021 - Server-Side Request Forgery	SSRF attacks	AS-001, network policies

8. Compliance Requirements

8.1 Regulatory Framework

Regulation	Applicability	Key Requirements	Status
GDPR	EU users	Data protection, consent, right to erasure	Required
ePrivacy Directive	EU users	Cookie consent, communication privacy	Required
French Data Protection Act	French users	Parental consent for minors <15	Required
Discord Developer ToS	All users	Platform usage, API compliance	Required
COPPA	US users <13	Parental consent for children	Conditional

8.2 GDPR Compliance Checklist

Requirement	Article	Implementation	Status
Lawful Basis	Art. 6	Consent + legitimate interest documentation	Planned
Consent Management	Art. 7	Explicit, granular consent mechanism	Planned
Right to Access	Art. 15	Data export functionality	Planned
Right to Erasure	Art. 17	Account deletion with cascade	Planned
Right to Portability	Art. 20	JSON data export	Planned
Data Protection by Design	Art. 25	Privacy-first architecture	In Progress
Breach Notification	Art. 33/34	72-hour notification process	Planned
DPO Appointment	Art. 37	Designated Data Protection Officer	Planned
Records of Processing	Art. 30	Processing activities register	Planned
Parental Consent (FR)	CNIL guidance	Age gate + parental consent for <15	Planned

8.3 Data Processing Activities Register

Activity	Data Categories	Legal Basis	Retention	Recipients
Account Registration	Discord ID, username, email	Consent	Until account deletion	Internal systems
Game Session	IP address, game actions	Legitimate interest	90 days	Internal systems
Campaign Data	User-generated content	Contract	Until deletion	Campaign members
Analytics	Anonymized usage data	Legitimate interest	2 years	Analytics systems
Security Logs	IP, user agent, timestamps	Legitimate interest	1 year	Security team

8.4 Discord Developer Compliance

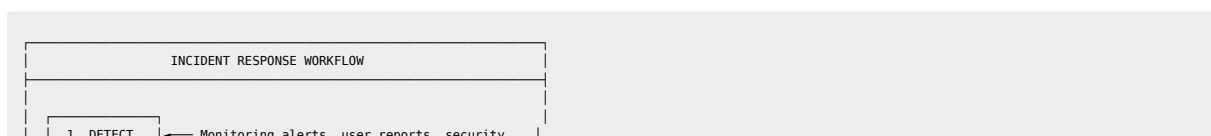
Requirement	Description	Implementation
Rate Limits	Respect Discord API rate limits	Rate limit handling, exponential backoff
Data Handling	Follow Discord's data policies	Data minimization, no unnecessary storage
Bot Guidelines	Follow Activity guidelines	Activity SDK compliance
User Privacy	Protect user data obtained via API	Encryption, access controls
Terms Compliance	No ToS violations	Regular policy review

9. Incident Response Plan

9.1 Incident Classification

Severity	Description	Examples	Response Time	Escalation
P1 - Critical	Service down, data breach, active attack	Production outage, confirmed breach	15 minutes	Immediate - all hands
P2 - High	Significant degradation, potential breach	Partial outage, suspicious activity	1 hour	Security lead + DevOps
P3 - Medium	Minor issues, no immediate risk	Single service issues, failed scans	4 hours	On-call engineer
P4 - Low	Informational, no impact	Minor alerts, scheduled maintenance	24 hours	Normal workflow

9.2 Incident Response Process





9.3 Communication Plan

Audience	P1 Critical	P2 High	P3 Medium	P4 Low
Security Team	Immediate	15 min	4 hours	Daily digest
Development Team	15 min	1 hour	8 hours	Weekly
Management	30 min	2 hours	Daily	Weekly
Users (if affected)	1 hour	4 hours	N/A	N/A
Regulators (GDPR)	72 hours (if breach)	72 hours	N/A	N/A

9.4 Contact Information

Role	Name	Contact	Backup
Security Lead	TBD	TBD	TBD
DevOps Lead	Florent CAPPELLETTI	Discord/Email	TBD
Project Manager	Quentin BERGER	Discord/Email	TBD
Legal/DPO	TBD	TBD	TBD

10. Security Testing Requirements

10.1 Testing Types and Frequency

Test Type	Scope	Frequency	Responsible	Tools
SAST	Source code analysis	Every commit	CI/CD Pipeline	SonarQube, Semgrep
DAST	Running application	Weekly	Security Team	OWASP ZAP, Burp Suite
SCA	Dependency scanning	Every build	CI/CD Pipeline	Dependabot, Snyk
Container Scanning	Docker images	Every build	CI/CD Pipeline	Trivy, Clair
Penetration Testing	Full application	Annually	External vendor	Manual testing
Security Code Review	Critical changes	Per PR	Development Team	Manual review

10.2 Security Test Cases

ID	Category	Test Case	Expected Result
ST-001	Authentication	Invalid JWT token	401 Unauthorized
ST-002	Authentication	Expired token	401 with refresh prompt
ST-003	Authorization	Access other user's data	403 Forbidden
ST-004	Authorization	IDOR attempt on campaigns	403 Forbidden
ST-005	Input Validation	SQL injection payload	Sanitized/rejected
ST-006	Input Validation	XSS payload in chat	Encoded output
ST-007	Rate Limiting	1000 requests/minute	429 Too Many Requests
ST-008	WebSocket	Malformed message	Connection preserved, message rejected

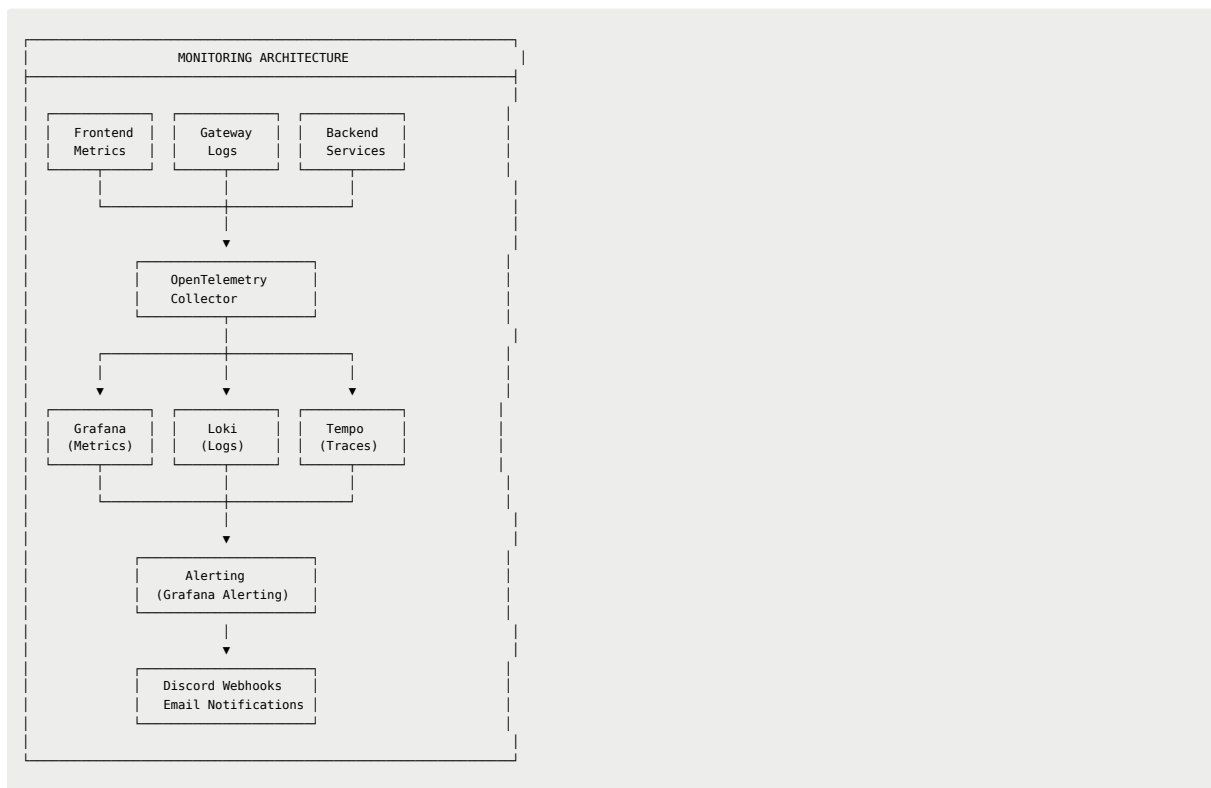
ID	Category	Test Case	Expected Result
ST-009	WebSocket	Unauthorized room join	Join rejected
ST-010	File Upload	Executable file upload	Upload rejected

10.3 Vulnerability Management SLAs

Severity	CVSS Score	Remediation SLA	Examples
Critical	9.0 - 10.0	24 hours	RCE, SQLi with data access
High	7.0 - 8.9	7 days	Auth bypass, sensitive data exposure
Medium	4.0 - 6.9	30 days	XSS, CSRF, limited impact
Low	0.1 - 3.9	90 days	Information disclosure, DoS

11. Monitoring and Logging Strategy

11.1 Security Monitoring Architecture



11.2 Security Events to Monitor

Event Category	Events	Alert Threshold	Priority
Authentication	Failed logins, token refresh failures	>10/min per IP	High
Authorization	Access denied, privilege escalation attempts	>5/min per user	High
Rate Limiting	Rate limit hits	>100/min per IP	Medium
Data Access	Bulk data exports, unusual queries	>1000 records	High
WebSocket	Connection floods, malformed messages	>1000 conn/min	High
Infrastructure	Container restarts, resource exhaustion	Any critical	High
Security Scans	Vulnerability discoveries	Any high/critical	High

11.3 Log Retention Policy

Log Type	Retention Period	Storage	Encryption
Security Logs	1 year	Cold storage	AES-256
Application Logs	90 days	Hot storage	AES-256
Access Logs	90 days	Hot storage	AES-256
Audit Logs	2 years	Cold storage	AES-256
Debug Logs	7 days	Hot storage	In-transit only

11.4 PII Handling in Logs

All logs must follow these PII redaction rules:

Data Type	Handling	Example
Email	Hash or mask	user@***.com or [EMAIL_REDACTED]
IP Address	Anonymize last octet	192.168.1.xxx
Discord ID	Allow (public identifier)	123456789012345678
Auth Tokens	Never log	[TOKEN_REDACTED]
Passwords	Never log	N/A
User Content	Truncate	First 50 chars with [TRUNCATED]

12. Business Continuity and Disaster Recovery

12.1 Recovery Objectives

Metric	Target	Description
RTO (Recovery Time Objective)	4 hours	Maximum acceptable downtime
RPO (Recovery Point Objective)	1 hour	Maximum acceptable data loss
MTTR (Mean Time To Recovery)	2 hours	Average recovery time target

12.2 Backup Strategy

Data Type	Backup Frequency	Retention	Storage Location	Encryption
Database	Hourly incremental, daily full	30 days	Offsite (different region)	AES-256
User uploads	Real-time replication	Until deletion	Multiple zones	AES-256
Configuration	On change	90 days	Version control	AES-256
Secrets	On change	Encrypted vault	Multiple replicas	AES-256

12.3 Disaster Recovery Scenarios

Scenario	Impact	Recovery Strategy	RTO
Single service failure	Degraded	Auto-restart, health checks	< 5 min
Database failure	Major	Failover to replica	< 30 min
Full region outage	Critical	Failover to secondary region	< 4 hours
Data corruption	Major	Point-in-time recovery	< 2 hours
Ransomware attack	Critical	Isolated backup restoration	< 8 hours

13. Security Awareness and Training

13.1 Training Requirements

Role	Training Topics	Frequency	Format
All Team Members	Security basics, phishing awareness, password hygiene	Annually	Online module
Developers	Secure coding, OWASP Top 10, code review	Quarterly	Workshop
DevOps	Infrastructure security, secrets management	Quarterly	Workshop
Project Leads	Incident response, compliance basics	Bi-annually	Workshop

13.2 Security Guidelines for Development

1. Code Review Requirements

- All code changes require security-focused review
- Use approved libraries for cryptography
- No hardcoded secrets (use secrets management)
- Input validation on all user inputs

2. Secure Development Checklist

- ☐ Input validation implemented
- ☐ Output encoding applied
- ☐ Authentication/authorization verified
- ☐ Sensitive data encrypted
- ☐ Error handling doesn't leak information
- ☐ Logging excludes PII

☐ Dependencies scanned for vulnerabilities

14. Document Control and Review

14.1 Document Information

Property	Value
Document Owner	Security Lead
Last Review Date	December 12, 2025
Next Review Date	March 12, 2026
Review Frequency	Quarterly
Classification	Internal - Confidential

14.2 Change History

Version	Date	Author	Changes
1.0	2025-12-12	Security Team	Initial document creation

14.3 Approval

Role	Name	Date	Signature
Project Lead			
Security Lead			
Technical Lead			

15. References and Sources

15.1 Standards and Frameworks

Reference	Version	URL
OWASP Top 10	2021	https://owasp.org/Top10/
OWASP ASVS	4.0.3	https://owasp.org/www-project-application-security-verification-standard/
NIST Cybersecurity Framework	2.0	https://www.nist.gov/cyberframework
ISO 27001	2022	https://www.iso.org/standard/27001
CIS Controls	v8	https://www.cisecurity.org/controls

15.2 Regulatory References

Reference	URL
GDPR Full Text	https://gdpr.eu/tag/gdpr/
CNIL Guidelines (French DPA)	https://www.cnil.fr/en
ePrivacy Directive	https://eur-lex.europa.eu/legal-content/EN/ALL/?uri=CELEX:32002L0058
Discord Developer Policy	https://discord.com/developers/docs/policies-and-agreements/developer-policy
Discord Terms of Service	https://discord.com/terms

15.3 Technical References

Reference	URL
ASP.NET Core Security	https://docs.microsoft.com/en-us/aspnet/core/security/
OWASP WebSocket Security	https://cheatsheetseries.owasp.org/cheatsheets/WebSockets_Cheat_Sheet.html
JWT Best Practices	https://auth0.com/docs/secure/tokens/json-web-tokens/json-web-token-best-practices
Docker Security	https://docs.docker.com/engine/security/
PostgreSQL Security	https://www.postgresql.org/docs/current/security.html

15.4 Tools and Resources

Tool	Purpose	URL
OWASP ZAP	DAST scanning	https://www.zaproxy.org/
Snyk	SCA/Dependency scanning	https://snyk.io/
Trivy	Container scanning	https://trivy.dev/
SonarQube	SAST	https://www.sonarqube.org/
Grafana	Monitoring/Alerting	https://grafana.com/

Appendix A: Security Checklist by Development Phase

Pre-Development

- ☐ Security requirements defined
- ☐ Threat model completed
- ☐ Security architecture reviewed
- ☐ Compliance requirements identified

Development

- ☐ Secure coding guidelines followed
- ☐ Input validation implemented
- ☐ Authentication/authorization tested
- ☐ SAST scans passing
- ☐ Dependency vulnerabilities addressed

Pre-Deployment

- ☐ Penetration testing completed
- ☐ Security configuration reviewed
- ☐ Secrets properly managed
- ☐ Logging and monitoring configured
- ☐ Incident response plan tested

Post-Deployment

- ☐ Security monitoring active
- ☐ Vulnerability management operational
- ☐ Regular security reviews scheduled
- ☐ Compliance audits planned

Appendix B: Glossary

Term	Definition
CIA Triad	Confidentiality, Integrity, Availability - core security objectives
DAST	Dynamic Application Security Testing
DDoS	Distributed Denial of Service
GDPR	General Data Protection Regulation
IDOR	Insecure Direct Object Reference
JWT	JSON Web Token
mTLS	Mutual Transport Layer Security
OWASP	Open Web Application Security Project
PII	Personally Identifiable Information
RBAC	Role-Based Access Control
RTO/RPO	Recovery Time/Point Objective
SAST	Static Application Security Testing
SCA	Software Composition Analysis
STRIDE	Spoofing, Tampering, Repudiation, Info Disclosure, DoS, Elevation of Privilege
WAF	Web Application Firewall
XSS	Cross-Site Scripting

This document is maintained by the DnDiscord Security Team and should be reviewed quarterly or upon significant system changes.